SOC L1 LAB · INC-005

INC-005 Detection Rule

One Suricata rule for outbound SYN sweeps, and the threshold that defines it

INCIDENT	INC-005 — Outbound port scan rule
REPORT DATE	2026-11-01
CLASSIFICATION	Lab exercise — sanitized for publication
ENVIRONMENT	Wazuh 4.14.7 · Debian 12 · QEMU/KVM
SEVERITY	Medium

Independent portfolio lab. No production systems, client data, or real credentials.

Contents

1. The rule
2. Test matrix
3. Why a local rule
4. Tuning
5. Gaps
6. Deployment
7. MITRE ATT&CK
8. Caveats

This is the local Suricata rule added for INC-005. It was loaded in Suricata 7.0.10 and tested against normal traffic, two legitimate request bursts, and an nmap scan on 2026-10-31.

The rule lives in `/var/lib/suricata/rules/local.rules` on the victim and is listed in `/etc/suricata/suricata.yaml` under `rule-files`.

---

1. The rule

```
alert tcp $HOME_NET any -> $EXTERNAL_NET any (
  msg:"LAB SCAN outbound SYN sweep";
  flags:S;
  detection_filter: track by_src, count 50, seconds 5;
  classtype:attempted-recon;
  sid:1000001; rev:1;
)
```

Field	Meaning
`$HOME_NET -> $EXTERNAL_NET`	Outbound direction; the lab's ET SCAN rules are mostly inbound
`flags:S`	TCP SYN packets only
`detection_filter`	50 SYNs from one source in 5 seconds
`classtype:attempted-recon`	Reconnaissance, severity 2
`sid:1000001`	Local range

`HOME_NET` is `10.0.2.15/32`; `EXTERNAL_NET` is `!$HOME_NET`.

---

2. Test matrix

Traffic	Alerts
Normal `apt-get update` + two `curl` requests	0
40 HTTP requests in a tight loop	0
60 HTTP requests in a tight loop	**10**
`nmap -sS --top-ports 200 --min-rate 500`	**144** (first run)

The 60-request burst is the false-positive boundary. The scan and the burst produce the same signature; the difference is volume and intent, not shape.

---

3. Why a local rule

ET Open contains scan signatures, but most are written for the inbound direction (`$EXTERNAL_NET -> $HOME_NET`). The lab's scan is outbound, from the victim to its gateway. A local rule makes that direction explicit and gives a testable threshold.

It also keeps the scenario honest: without the rule, the scan can be invisible to Suricata even though the packets are on the wire.

---

4. Tuning

4.1 Threshold

50/5 s is deliberately low enough to catch a fast top-200 scan. It also catches a 60-request load test.

Options:

- raise to 100/5 s to reduce load-test noise, at the cost of missing slower scans;
- baseline known scanners and load generators;
- correlate with authentication failures or exploit signatures;
- use a flow-based detector that counts unique destinations, not packets.

4.2 Direction

If the sensor sees inbound traffic, add a second rule for `$EXTERNAL_NET -> $HOME_NET` or rely on ET SCAN. The two directions answer different questions.

4.3 Placement

The rule is on the victim's `eth0` . In a real estate, put the sensor on a span port or a network tap that sees the segment, not just one host.

---

5. Gaps

Gap	Consequence
Outbound-only	Inbound scans of the VM are not covered by this rule
Packet-count threshold	Legit bursts false-positive; slow scans evade
One source, one destination in the lab	A subnet sweep is not represented
No follow-on correlation	Scan and exploit are separate alerts
No unique-destination count	The rule cannot distinguish wide recon from a busy client

---

6. Deployment

```
sudo tee /var/lib/suricata/rules/local.rules >/dev/null <<'EOF'
alert tcp $HOME_NET any -> $EXTERNAL_NET any (msg:"LAB SCAN outbound SYN sweep"; flags:S;
detection_filter: track by_src, count 50, seconds 5; classtype:attempted-recon; sid:1000001; rev:1;)
EOF

sudo python3 - <<'PY'
p="/etc/suricata/suricata.yaml"
t=open(p).read()
if "- local.rules" not in t:
    t=t.replace("rule-files:\n  - suricata.rules", "rule-files:\n  - suricata.rules\n  -
local.rules", 1)
    open(p,"w").write(t)
PY

sudo suricata -T -c /etc/suricata/suricata.yaml
sudo systemctl restart suricata
```

Verify:

```
sudo grep -c "LAB SCAN" /var/lib/suricata/rules/local.rules
sudo grep -n "local.rules" /etc/suricata/suricata.yaml
```

The Wazuh side needs no new decoder: the existing Suricata filter forwards the alert and stock rule 86601 fires.

---

7. MITRE ATT&CK

Technique	ID	Evidence
Network service discovery	T1046	SYN sweep across 200 ports
Active scanning	T1595	nmap from the victim

---

8. Caveats

- Tested on Suricata 7.0.10 with 8,234 ET Open rules plus the local rule.
- The threshold is a lab choice, not a production recommendation. Tune against the estate's scanner and load-test baseline.
- The rule detects a scan, not a compromised host. Host telemetry decides that.
- QEMU user networking limits the lab to outbound scans; the bridge upgrade is the path to an inbound version.